

VULNERABILITY ASSESSMENT REPORT

Metasploitable 2 · Network Security Lab

Author	Ilyas Rafiq
Date	April 6, 2026
Scanner	Tenable Nessus Essentials (localhost:8834)
Scan VM	Parrot OS (VMware)
Target	Metasploitable 2 — 192.168.195.131
Network	192.168.195.0/24
Class.	Confidential – Lab Use Only

TASK 1

Vulnerability Scan — Metasploitable 2

TASK 2

Network Discovery Scan — 192.168.195.0/24

Prepared using Tenable Nessus Essentials on Parrot OS (VMware Workstation)

TASK 1 — Vulnerability Assessment on Metasploitable 2

1. Objective

The primary objective of this lab exercise is to perform a comprehensive vulnerability scan against a deliberately insecure Linux target — Metasploitable 2 — using Tenable Nessus Essentials. The assessment aims to identify critical security flaws, analyze their risk impact, and propose actionable remediation strategies. This exercise reinforces fundamental concepts in penetration testing, network security auditing, and vulnerability lifecycle management.

2. Tools & Environment

Attacking / Scanning VM	Parrot OS (VMware Virtual Machine)
Vulnerability Scanner	Tenable Nessus Essentials — Web UI at localhost:8834
Target Virtual Machine	Metasploitable 2 (Deliberately Vulnerable Linux)
Target IP Address	192.168.195.131
Network Configuration	Host-Only / NAT (VMware Network Adapter)
Scan Profile	Basic Network Scan (Nessus Default)

3. Scan Summary

Scan Name	Total Vulnerabilities	Hosts Scanned	Critical Issues
task1	63	1	4+

4. Critical Vulnerabilities Discovered

The following four vulnerabilities were classified as Critical (CVSS score 9.0+) by Nessus Essentials. Each poses a direct risk of full system compromise or sensitive data exposure.

4.1 Debian OpenSSH / OpenSSL RNG Weakness		CRITICAL
Plugin ID	#32314	
CVSS v2.0	10.0 (Maximum)	
Family	Gain a Shell Remotely	
Published	May 14, 2008	
Port	SSH (TCP/22)	

Description:

The remote SSH host key was generated on a Debian or Ubuntu system running a version of OpenSSL with a critically flawed pseudo-random number generator (PRNG). The bug drastically reduces the possible key space, allowing an attacker to enumerate all plausible key pairs. A successful attack enables Man-in-the-Middle (MITM) interception of SSH sessions, passive decryption of encrypted communications, and unauthorized remote access without knowing the original passphrase.

Remediation:

Immediately regenerate all cryptographic material on the affected host, including SSH host keys, SSL/TLS certificates, and OpenVPN key pairs. Apply all available Debian/Ubuntu security patches and upgrade OpenSSL to a non-vulnerable version.

4.2 UnrealIRCd Backdoor Detection

CRITICAL

Plugin ID	#46882
CVSS v2.0	10.0 (Maximum)
Family	Backdoors
Published	June 14, 2010
Port	IRC (TCP/6667)

Description:

A backdoor was intentionally introduced into the UnrealIRCd source code between November 2009 and June 2010. Any remote attacker who sends a specially crafted string to the IRC port can trigger the backdoor and execute arbitrary system commands with the privileges of the IRC daemon process. This is a classic supply-chain attack — the compromised source archive was distributed from the official mirrors, meaning administrators who followed standard installation procedures unknowingly installed the backdoor.

Remediation:

Immediately remove the compromised version of UnrealIRCd. Download a clean, verified copy from the official repository and validate integrity using both MD5 and SHA-1 checksums before reinstallation. Review all server logs for signs of backdoor exploitation.

4.3 VNC Server 'password' Password

CRITICAL

Plugin ID	#61708
Port	TCP/5900 (VNC)
Auth Result	Login Succeeded
Credential	"password" (default/weak)

Description:

The VNC (Virtual Network Computing) service running on TCP port 5900 is protected by a trivially guessable password — the string "password". Nessus Essentials successfully authenticated to the VNC server using this credential without any lockout or rate-limiting. This exposes the full graphical desktop of the target machine to any attacker on the network, enabling unrestricted interactive control of the system. Nessus output: *Nessus logged in using a password of "password"*.

Remediation:

Replace the current VNC password with a strong, randomly generated credential of at least 16 characters. If VNC remote access is not required, disable the service entirely. Consider replacing VNC with a VPN-protected SSH tunnel for remote administration.

4.4 SSL 2.0 / SSL 3.0 Protocol Support

CRITICAL

Plugin ID	#20007
CVSS v3.0	9.8 (Critical)
Family	Service Detection
Published	October 12, 2005
Affected	SSLv2, SSLv3

Description:

The remote service accepts connections using SSL 2.0 and SSL 3.0, both of which have been formally deprecated due to serious cryptographic weaknesses. SSL 2.0 is vulnerable to MITM attacks through cipher suite downgrade, protocol version rollback, and message truncation attacks. SSL 3.0 is susceptible to the POODLE (Padding Oracle On Downgraded Legacy Encryption) attack, which can expose session cookies and sensitive data in plaintext. Continued support violates PCI DSS requirements, NIST SP 800-52 guidelines, and modern TLS best practices.

Remediation:

Disable SSLv2 and SSLv3 across all services (HTTPS, IMAPS, SMTPS, etc.). Configure the server to support only TLS 1.2 and TLS 1.3 with strong forward-secret cipher suites. Remove RC4, DES, 3DES, and EXPORT cipher suites from the allowed list.

5. Observations

- **Intentional vulnerability exposure:** Metasploitable 2 is a deliberately outdated and misconfigured Linux distribution designed for security training. All 63 detected vulnerabilities reflect real-world risks present in unpatched, production-like systems.
- **Default credential acceptance:** The VNC service accepted login with the literal string "password" — a clear credential hygiene failure that would be trivially exploitable in any real environment.
- **Deprecated cryptographic protocols:** Both SSL 2.0 and SSL 3.0 remain active, violating PCI DSS v4.0, NIST SP 800-52 Rev.2, and HIPAA technical safeguards.
- **Supply-chain risk demonstrated:** The UnrealIRCd backdoor is a historical case study in software supply-chain compromise, bypassing most endpoint defenses.
- **Cryptographic key compromise:** The Debian OpenSSL RNG weakness demonstrates how a single packaging flaw in a core library can nullify the security of all dependent services.
- **Automation effectiveness:** Nessus identified all four critical vulnerabilities within a single automated scan, validating authenticated scanners as a first-pass assessment tool.

6. Remediation Summary

Vulnerability	Severity	Recommended Remediation
Debian OpenSSH / OpenSSL RNG	CRITICAL	Regenerate SSH keys, SSL certs, OpenVPN pairs. Patch OpenSSL immediately.
UnrealIRCd Backdoor	CRITICAL	Remove binary. Re-download from official source, verify MD5/SHA-1.

VNC Weak Password	CRITICAL	Replace default password (16+ chars) or disable VNC service.
SSL 2.0 / SSL 3.0 Support	CRITICAL	Disable SSLv2/SSLv3. Enforce TLS 1.2+ with forward-secret ciphers.

7. Conclusion

This lab exercise successfully demonstrated the practical application of Tenable Nessus Essentials as an automated vulnerability assessment tool. The scan against Metasploitable 2 revealed 63 total vulnerabilities, including four rated Critical (CVSS 9.8–10.0) that represent real attack vectors exploitable by any moderately skilled adversary.

The findings highlight three foundational security principles: the necessity of patch management (outdated SSL protocols, unpatched OpenSSL), the importance of credential hygiene (VNC default password), and the growing threat of supply-chain attacks (UnrealIRCd backdoor). In a production environment, any one of these vulnerabilities could result in complete system compromise, data exfiltration, or ransomware deployment.

Automated vulnerability scanners like Nessus provide an efficient first-pass security audit, but they should be complemented by manual penetration testing, secure configuration baselines (CIS Benchmarks), and continuous monitoring solutions.

8. References

- [1] Tenable Nessus Essentials Documentation — <https://docs.tenable.com/nessus>
- [2] CVE-2008-0166: Debian OpenSSL Predictable Random Number Generator
- [3] CVE-2010-2075: UnrealIRCd 3.2.8.1 Backdoor
- [4] CVE-2011-3389: BEAST Attack on SSL/TLS (POODLE variant)
- [5] Metasploitable 2 Documentation — Rapid7 / OffSec
- [6] NIST SP 800-52 Rev.2: Guidelines for TLS Implementations
- [7] PCI DSS v4.0 — Requirement 4: Protect Cardholder Data in Transit

TASK 2 — Network Discovery Scan

1. Objective

To discover active hosts and identify open ports within the target network range using Tenable Nessus Essentials. This scan establishes network visibility as a prerequisite to deeper vulnerability assessment.

2. Tools Used

Operating System	Parrot OS (VMware Workstation)
Vulnerability Scanner	Tenable Nessus Essentials
Virtualization	VMware Workstation
Scan Type	Host Discovery
Target Network	192.168.195.0/24

3. Methodology

- Started the Nessus service on the Parrot OS scanning VM.
- Opened the Nessus Web UI in browser at **https://localhost:8834**.
- Created a new scan and selected the **Host Discovery** scan template.
- Entered the target network range: **192.168.195.0/24**.
- Launched the scan and monitored progress from the Nessus dashboard.
- Waited for scan completion (~2 minutes) and reviewed results.

4. Scan Results

4.1 Active Hosts Discovered

#	IP Address	Status
1	192.168.195.254	● Active
2	192.168.195.128	● Active
3	192.168.195.2	● Active
4	192.168.195.1	● Active

4.2 Open Ports on 192.168.195.1

Port	Protocol	Service	Risk Note
135	TCP	RPC	Remote Procedure Call — restrict access
139	TCP	NetBIOS	Exposes system info — disable if unused
445	TCP	SMB	Potential unauthorized access if unpatched
49664–49670	TCP	Dynamic / RPC	Ephemeral RPC ports — monitor for misuse

5. Vulnerability Summary

Total Hosts Scanned	4
Active Hosts Found	4
Scan Type	Host Discovery
Scan Status	Completed
Time Taken	~2 minutes
Critical Issues	None detected in this scan phase

6. Risk Analysis

- **SMB (Port 445):** Open SMB ports may allow unauthorized file access or lateral movement if the service is unpatched or misconfigured.
- **NetBIOS (Port 139):** NetBIOS can expose system hostname, workgroup, and user information to unauthenticated network queries.
- **RPC / Dynamic Ports:** Multiple open RPC ports increase the attack surface and may be leveraged for privilege escalation if underlying services are vulnerable.
- **Attack Surface:** Four active hosts with exposed services represent a meaningful internal network footprint requiring further assessment.

7. Recommendations

- Disable unnecessary ports using host-based firewall rules (e.g., iptables / Windows Firewall).
- Secure SMB services — require SMB signing and restrict access to authorised hosts only.
- Disable NetBIOS over TCP/IP if not required for legacy application compatibility.
- Limit dynamic RPC port ranges and monitor them with an IDS/IPS solution.
- Apply all pending OS and service security patches on each discovered host.
- Conduct a follow-up full vulnerability scan (Basic Network Scan) on each active host.

8. Conclusion

The network discovery scan successfully identified four active hosts and enumerated open ports on the primary Windows host (192.168.195.1). While no critical vulnerabilities were flagged at this discovery phase, the presence of exposed SMB and NetBIOS services represents a meaningful security risk that warrants immediate hardening and a follow-up authenticated vulnerability scan.

Network discovery scans are a vital first step in any security assessment methodology — they provide the asset inventory needed to prioritise and scope deeper testing activities, and directly inform risk-based remediation planning.